DLA PIPER

From vulnerability management to real, risk-based exposure management

Steve Davies & Colin Pike



Resilience

Resilience

- the capacity to **withstand** or to recover quickly from difficulties; toughness.

Cyber resilience

- an organization's capacity to **anticipate, withstand**, recover from, and **adapt to cyberattacks** and disruptions, ensuring critical functions continue despite adverse events, rather than just preventing breaches, by integrating people, processes, and technology for business continuity.

Agenda

- What is Exposure Management (XM)?
  Understanding attacker-centric cybersecurity and the evolution beyond traditional vulnerability management.
- Exposure Management vs Vulnerability Management
  How each approach differs in scope, prioritisation, and real-world value to the firm.
- Managing real-world risks
  Insights into the modern attack surface and the challenges faced by law firms today.
- Maximising Exposure Management
  Enterprise-wide strategies to reduce risk, break silos, and improve operational resilience.
- Conclusion & Key Takeaways
  How risk-based exposure management strengthens the firm’s cyber resilience and reduces breach likelihood.

What Is Exposure Management?

Exposure management is the continuous practice of identifying, assessing and remediating vulnerabilities, misconfigurations and identity exposures before they can be exploited.

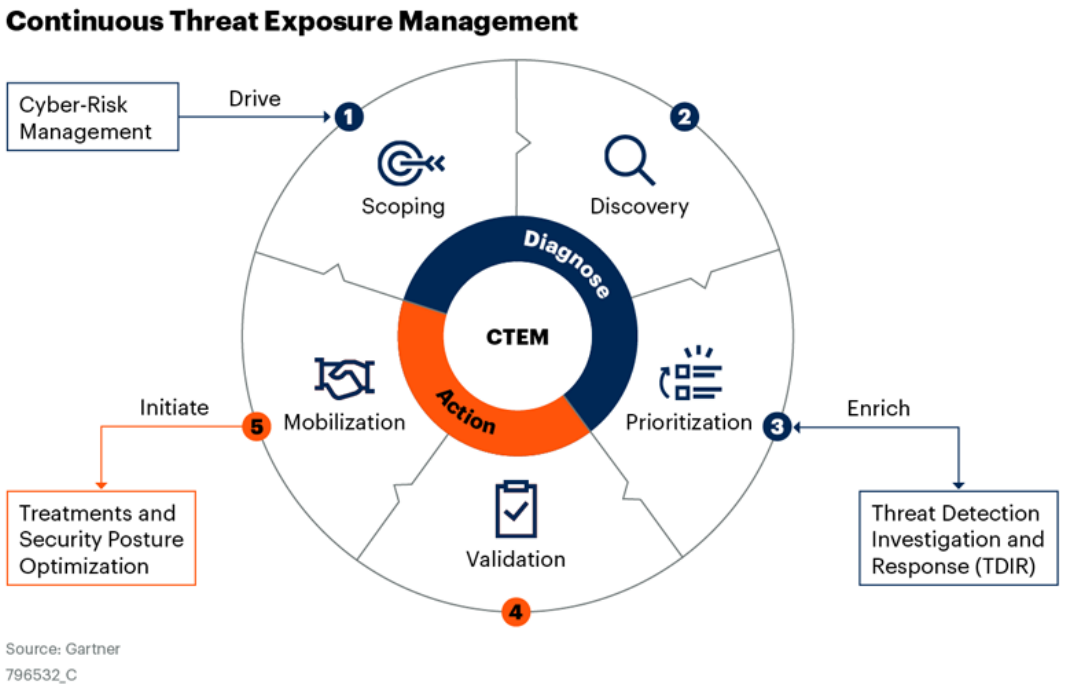
Exposure management represents the evolution of vulnerability management in response to the modern attack surface.

Key points

Attacker-focused: Looks at the firm the way attackers do, identifying all possible entry points.

Driven by threat intelligence: Considers real-world exploit trends, not just severity scores.

Prioritises what matters most: Focuses on real world exploitable exposures with the highest business risk/impact.



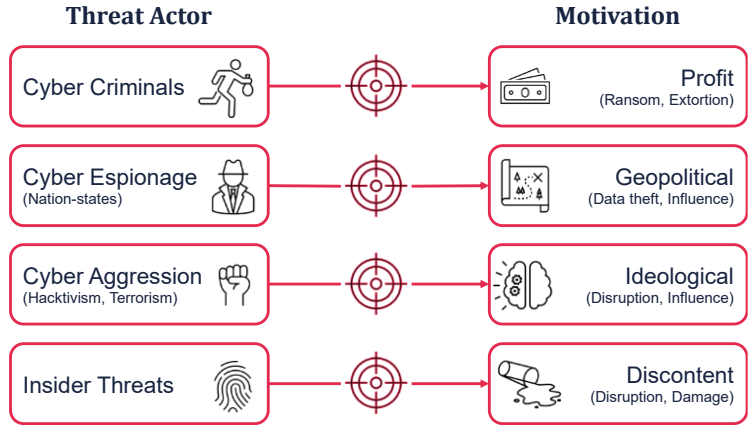
Exposure Management vs Vulnerability Management

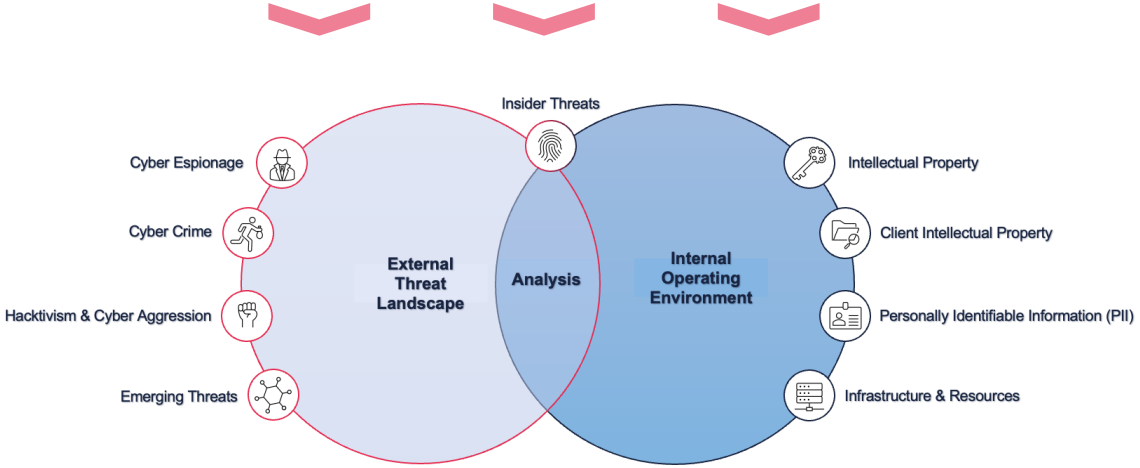
ASPECT	EXPOSURE MANAGEMENT	VULNERABILITY MANAGEMENT
Scope	Vulnerabilities, misconfigurations, identities, N-party supply chain, industry peers	Known CVEs and patches
Prioritization	Real-world risk: threat intel, exploitability, impact, attack-path	CVSS scores (often base)
Approach	Continuous, proactive, attack-centric	Scan, fix, repeat
Visibility	Full attack surface & context: On-prem, cloud, SaaS, identities, external assets, supply chain	Only scanned assets
Outcomes	Resilience to real-world threats, exposure reduction, higher standard of readiness, informed incident response	Point-in-time compliance
Driving Question	How can attackers break in?	What vulnerabilities must we fix?

Managing Real-World Risks

Threat Profile of a Law Firm

- Cyber Crime is at new heights with groups like Scattered Spider taking a vertical perspective around potential victims
- Threat-actors are increasingly focusing on cloud services and updating their TTPs to exploit cloud
- Insider-threat is an affordable strategy for threat-actors looking to defeat security investments
- Security tools and platforms are susceptible to interruption from changes in technology (i.e. cloud adoption)
- Regulators increasingly taking a *'Minimum viable security / resilience, i.e. what is legally and reputationally defensible'* perspective post-incident (fines!)
- Geopolitical Instability: China and US, Russia and EU
- High-profile representation including appointments and client, attracting the attention of activists
- Innovation (including AI) introducing new classes of attack and exploitation





Why is XM critical for Managing Real-World Risk

Attack surfaces are expanding and threats are accelerating.

- Law firms are dealing with a rapidly growing and increasingly complex digital footprint.
- This expansion creates more points of entry for attackers—and threat actors are becoming faster, more automated, and more capable thanks to AI.
- Time between vulnerability disclosure and exploitation is shrinking.
  - 2019: Average time-to-exploit (TTE) was 63 days.
  - 2022: TTE dropped to 32 days.
  - 2023: TTE plunged to just 5 days on average.
  - 2025: Current analysis suggests many critical vulnerabilities are weaponized within hours of public disclosure

- Threat-actors are innovating faster than many organisations can respond with traditional vulnerability management practices. In response we must invest in Exposure Management efforts which are focused on coverage and outcomes.
- We're approaching a near-term future where threat-actors will be able develop exploits, detect vulnerable systems and exploit them at machine speed. This ***"industrialisation of intrusion"**** threatens to disrupt and reshape how firms can safely employ technology.

Gartner

"By 2026, organizations prioritizing their security investments based on a continuous exposure management programme will be three times less likely to suffer from a breach."

– Gartner, Implement a Continuous Threat Exposure Management (CTEM) Program, July 2022

* ***On the Coming Industrialisation of Exploit Generation with LLMs,*** *Sean Heelan's Blog, 2026* - https://sean.heelan.io/2026/01/18/on-the-coming-industrialisation-of-exploit-generation-with-llms/

Maximizing Exposure Management Effectiveness

Enhance Visibility

IDENTIFYING VULNERABILITIES & MISCONFIGURATIONS BEFORE EXPLOITATION

As firms adopt new technology & develop new services their attack surface grows. Offensive and defensive research efforts are in a race to identify new vulnerabilities.

- Maximise coverage of all detection capabilities. Avoid 'out of scope' blind spots.
- Ensure you can see all assets, including cloud, shadow IT, and third-party systems.
- Apply commercial tension to suppliers to map and validate the XM maturity. Start with out-of-band patch management.
- Challenge redaction ping-pong. Responsibilities should be shared but processes and coverage should be transparent.

Prioritize by Risk

ASSESS, VALIDATE & PRIORITIZE TO MAINTAIN AN EFFECTIVE SECURITY POSTURE

Firms often implement vulnerability management capabilities to address compliance requirements. These are the foundation to effective exposure management processes.

- Prioritise & address findings in-line with criticality AND relevance to your survivability
- Remember the cyber kill-chain OR the survivability onion
- Define a threat detection and investigation (TDIR) process
- Utilise attack-path mapping & CVSS details, not just CVSS severity (read them!)
- Leverage generative & agentic AI to assist with analysis, validation & testing

Automate what you can

AUTOMATION CAN SIGNIFICANTLY ENHANCE EXPOSURE MANAGEMENT EFFORTS

Security investments now include opportunities to automate analysis & remediation which can reduce the time to respond as well as reducing the risks associated with manual processes.

- Aim to fully automate the end-to-end workflow of exposure management from detection to remediation
- Reevaluate investments that a fulfil a limited role in exposure management
- Revisit roll-back and recovery processes

Collaborate

FOSTER A CULTURE OF ROUTINE, CROSS-TEAM ASSESSMENT & RESPONSE TO THREATS

Security, IT, cloud, identity & assurance teams need to work together to define, implement & operate a firm-wide exposure management regime.

- Employ adversarial thinking to foster a Purple Team mindset
- Provide advisory and service support around projects & initiatives
- Provide threat briefings and actionable insights around developing cyber trends & emerging threats
- Extend cyber security capabilities and services across your firm and wider group of related entities
- Provide tailored training to address risks associated to specific employee roles

DLA Piper's Approach



Vulnerabilities, Misconfigurations, Identity Risks

- EDR & network scans
- CSPM & SSPM
- DAST
- Attack Surface Monitoring
- CTI curation & alerting
- Penetration Testing
- Public Reporting (security.txt)

Convert severity to business risk (exposure)

- Attack path analysis
- Threat modelling
- Group engagement
- Client engagement

Automate patching, Config changes, Identity Response (under SLA)

- ITSM & SOAR
- Device Management
- Remote Configuration Management

Verify Remediation with scans/tests

- EDR & network scans
- CSPM
- SSPM
- DAST
- Attack Surface Monitoring
- Re-testing

Track remediation, MTTR and SLAs. Review exposure trends

- XM reporting
- Service Owner 1:1s
- ITLT/ISLT compliance forum
- Enterprise Risk Management
- Internal Audit

Conclusion & Takeaways

Exposure Management = Real Risk Reduction

Exposure Management is vulnerability management evolved. It's the operationalisation of cyber threat intelligence resulting in cyber posture enhancement and validation.

Law Firms that develop robust exposure management processes materially reduce their likelihood of suffering a cyber attack. Demonstrating this capability will result in trust with clients who recognise their exposure to the increasingly hostile threat landscape is greatest in their supply-chain.

Your Key Takeaways

- **Aim to see everything:** Full visibility of the attack surface is non-negotiable
- **Prioritise by real-world risk:** Focus effort on exposures attackers can actually exploit
- **Automate remediation:** Move from manual triage to AI-assisted, continuous fix workflows
- **Break down silos**: Bring IT, Cloud, Identity, and Security into one coordinated motion
- **Drive resilience, not compliance:** Reduce breach likelihood and strengthen business continuity

Thank You

Colin Pike

Vulnerability Management Specialist, DLA Piper



About Colin
Over the last decade Colin has built and run our vulnerability management capability and is now focused on advancing Exposure Management across the firm.

Outside of work Colin is a Liverpool fan and enjoy getting out on the golf course.

Email: colin.pike@dlapiper.com
LinkedIn: in/colin-pike

Steve Davies

Head of Cyber Security, DLA Piper



About Steve
I'm passionate about all things technology and cyber especially detection & response, CTI, exposure management & systems architecture.

Email: steve.davies@dlapiper.com
LinkedIn: in/sldavies
Signal: northvein.64
Socials: northve.in